Initial GRC Assessment

Company: Company name / anonymised

Business sector: Secure storage of valuable assets for collectors

Interview date: 8 September 2026

People interviewed: Company Director (2.5-hour interview); 3 employees (15-minute informal discussion during lunch)

Assessment conducted by: Bruno, as part of cybersecurity training

The GRC (Governance, Risk and Compliance) approach is not a one-off exercise, but rather a process of ongoing assessment and continuous improvement.

CONFIDENTIAL

Scope: Governance, risk, access, ERP, workstations, backups, connected physical security and third-party providers.

1. Executive Summary

The company provides storage services for valuable assets in a highly secure physical environment. However, its operations increasingly rely on digital services: a third-party-hosted ERP system, customer platform, email, workstations, remote access, API interfaces and payment tools.
This initial assessment highlights a contrast between well-structured physical security and cybersecurity governance that remains relatively informal. Several useful controls are already in place, including individual ERP accounts, segregation of access rights, movement traceability, separation of video-surveillance equipment from the office network, and backups reported as being performed daily. However, multi-factor authentication was not enabled at the time of the interview, remote access is not governed by a formal policy, incident detection and response are not documented, and there is significant dependency on the Director and the IT provider.
The priority is therefore to reduce the risk of identity and ERP compromise, technically confirm backup and restoration mechanisms, and then formalise a simple incident response process suited to an organisation of five employees.

Key findings:

- Leakage of the customer database and asset inventory represents the most sensitive risk, as this data is highly confidential.
- An intrusion into the ERP system allowing inventories to be modified or deleted would have a major operational impact.
- The building is new, earthquake-resistant and physically well secured, but a natural disaster would remain a high-impact scenario.
- Customers using the exchange platform may use weak passwords, without two-factor authentication.
- No formal security awareness programme existed before this interview.

2. Methodology

The assessment uses the NIST CSF 2.0 framework to structure the discussion with the Director around six functions: Govern, Identify, Protect, Detect, Respond and Recover. The CIS Controls (Implementation Group 1) will serve as a practical checklist for implementing essential cyber hygiene measures appropriate to the size of the company.

Six scenarios guided the interview: phishing/email, ERP and remote working, ransomware, backups, connected devices (doors, cameras), and third-party access.

3. Asset Mapping

Simplified overview of the systems and their criticality level.

Asset / system	Function	Criticality	Access	Provider
ERP	Inventory, customer database, billing	Critical	Employees + remote working (one access without VPN identified)	IT provider (to be confirmed)
Workstations (Mac)	ERP access, email	Critical	Individual account per employee	IT provider
Email	Internal and customer communications	Critical	One address per employee, created by the provider	IT provider
Connected doors	Physical access to the warehouse	Critical	Keypad code per employee, remote locking by the Director	Security company (remote access)
Cameras	Video surveillance (10 cameras)	High	6-month recording, tablet not connected to the IT network	Security company (remote access)
Network / Wi-Fi	Infrastructure	Critical	No separate guest network identified	Not determined
Backups	Business continuity	Critical	Daily backup reported, restoration not tested	IT provider
Website / exchange platform	Web presence, resale between collectors	Medium	Public access + customer accounts (without two-factor authentication)	Hosting provider and web protection service
Automation provider	Physical storage management (timestamped tracking codes)	Critical	All movements recorded with date, time and person	External integrator

Fields marked “Not determined” could not be completed during the interview. This is itself a finding of this initial assessment and should be clarified.

4. Findings, Risks and Recommendations

In accordance with the GRC methodology, each finding is presented separately from its associated risk and recommendation, in order to distinguish what was observed from what remains a hypothesis or an action to be taken.

Topic	Observed finding	Associated risk	Recommendation
Governance	Responsibility for IT and cybersecurity rests exclusively with the Director, who is also the sole decision-maker in the event of an incident.	If the Director is absent or overloaded, no designated backup person is available to make decisions or act quickly.	Designate a backup employee (for example, to carry out a quarterly review) and formalise a simple decision-making process in the event of an incident.
ERP and remote working	One employee accesses the ERP system and exchange platform from home without a secure connection or VPN; the Director does the same when working remotely. MFA is not enabled.	Unprotected remote access without two-factor authentication significantly increases the risk of an ERP account being compromised, with a potentially high impact on customer data and inventory.	Enable multi-factor authentication (MFA) on ERP and email accounts, including Microsoft and Google, and secure remote access (VPN or equivalent).
Email and awareness	Communication relies heavily on email. No formal phishing awareness programme existed before the interview.	According to the risk matrix, phishing/email account compromise is considered the most likely and highest-impact scenario.	Provide regular, short awareness sessions on recognising fraudulent emails, in addition to MFA.
Physical security	The doors can be controlled remotely from the Director's phone; each employee has an individual keypad code. The cameras are on a separate network, not connected to the ERP system or workstations.	The security provider has remote access to the doors and cameras; the exact scope of its permissions was not verified during the interview.	Formally request details of the security provider's remote access rights and confirm that there are no unjustified permanent administrator accounts.
Backups and continuity	The IT provider reports daily backups that can be restored within a few minutes, but no actual restoration test has been performed to date.	An untested backup does not guarantee successful restoration; reverting to paper records is estimated to require approximately one month of work.	Schedule an actual restoration test with the IT provider and retain written evidence of the test.
Third-party providers	Several third-party providers have direct or remote access to systems (IT, security, automation, hosting, valuation API connections and payments).	The exact level of access and whether these providers maintain permanent administrator accounts could not be confirmed during the interview.	Establish a formal inventory of providers, their access and permissions, with written confirmation that no unjustified permanent administrator accounts exist.
Customer exchange platform	Customers log in to the platform with a username and password, without two-factor authentication.	A weak or compromised customer password could allow an undetected change to the value or status of an asset.	Require two-factor authentication for customer accounts on the platform.
Workstations	Workstations are provided by the company. The presence of antivirus software has not	Without EDR and update monitoring, compromise of a workstation might not be	Deploy EDR on all workstations, with alerts reported to the Director, and

Topic	Observed finding	Associated risk	Recommendation
	been technically confirmed, no EDR is in place, and update monitoring is not guaranteed.	detected before causing significant impact.	verify that automatic updates are enabled.

5. Assessment against NIST CSF 2.0

GOVERN: Responsibility for cybersecurity rests solely with the Director, who centralises all decisions in the event of an incident.

IDENTIFY: The critical assets identified are the ERP system, customer database and asset inventory, workstations, access control and backups.

PROTECT: Each employee has an individual account, but MFA is not enabled, antivirus and EDR protection have not been technically confirmed, and remote access is not secured.

DETECT: There is currently no mechanism to determine whether an intrusion is taking place or has occurred.

RESPOND: In the event of an incident, the current response is to call the IT provider; no formal procedure exists at present.

RECOVER: According to the IT provider, daily backups could be restored within a few minutes, but this has not been tested; reverting to paper records would require approximately one month of work.

6. Risk Matrix (Likelihood x Impact)

Scale used: likelihood and impact rated from 1 (low) to 3 (high). The company estimates that it could absorb a financial impact of up to approximately CHF 100,000.

Risk	Likelihood	Impact	Score
Phishing / email account compromise	3	3	9
ERP account compromise during remote working	3	3	9
Ransomware	2	2	4
Website unavailability	2	1	2
Door access control compromise	1	2	2
ERP backup cannot be restored	1	1	1
Camera compromise (IoT)	1	1	1
Inactive employee account remains active	0	0	0

This ranking illustrates an important point: protecting the website is probably not the most urgent priority. Compromise of the ERP system through remote working would have a far greater business impact.

7. Existing Controls Already Observed

The assessment does not identify weaknesses only. Several existing practices already provide a useful foundation:

- Individual ERP accounts for employees.
- Segregation of access rights between operations and accounting.
- Traceability of physical movements by user, date and time.
- A procedure is in place for immediate removal of access when an employee leaves.
- Individualised physical access control and monitoring of the storage facility.
- Reported separation of cameras and security systems from workstations and the ERP system.
- Daily backups reported by the IT provider.
- Rapid management response: following the interview, the Director contacted the IT provider and initiated the implementation of 2FA.

8. Action Plan

0 to 30 days

Enable MFA on employee ERP accounts and require it for customer accounts on the exchange platform.
Clarify who, in addition to the Director, can carry out a quarterly review so that all decisions do not depend on a single person.
Review remote access to the ERP system and verify existing administrator accounts.
Ask the IT provider to perform an actual backup restoration test.
Establish a list of providers and existing API connections (valuation, payment, security, automation).

1 to 3 months

Inventory the equipment and applications used (names and purposes).
Document the employee onboarding/offboarding procedure in writing (already applied in practice).
Define a simple access management policy.
Document the network segmentation already in place between IoT equipment (doors, cameras) and workstations.
Draft a short incident response procedure that is accessible to the relevant people.
Deploy EDR on each workstation, with reporting and alerts to the Director.

3 to 6 months

Provide employees with regular cybersecurity awareness training (with phishing as the priority).
Test backups periodically.
Review each person’s access rights.

Reassess risks related to third-party providers, if possible with support from a network or infrastructure architect.
Conduct a simple incident response exercise.

9. Conclusion and Next Steps

The priority is not to deploy numerous tools immediately, but to establish cyber hygiene appropriate to the size of the company and the value of the assets being protected: two-factor authentication, an actual backup restoration test, and clarification of third-party access.

A second phase will make it possible to technically validate certain findings with the relevant providers (IT provider, security company, hosting provider and automation integrator).

On the evening of the interview, the Director confirmed the intention to implement MFA for every employee and to activate the backups without delay, representing a first concrete step forward.